PENETRATION TESTING REPORT

Target: Metasploitable 2

Full-Cycle Ethical Hacking Assessment — CEH Practical Portfolio

Submitted By	Pavan N
Course	Cybersecurity / Ethical Hacking
Target Machine	Metasploitable 2 (192.168.56.101)
Attacker Machine	Kali Linux (192.168.56.104)
Date	18-03-2026
Tools Used	Nmap · Nessus Essentials · Metasploit Framework · enum4linux · nbtscan
Classification	Confidential — Authorised Educational Assessment

⚠ Conducted in an isolated lab environment. No production systems were targeted. ⚠

1. Executive Summary

This report documents a comprehensive penetration test conducted against Metasploitable 2, a purposely vulnerable Linux virtual machine maintained by Rapid7. The assessment was performed in a fully isolated VirtualBox lab environment as part of the Certified Ethical Hacker (CEH) practical portfolio.

The engagement followed the standard five-phase penetration testing methodology: Footprinting & Reconnaissance → Network Scanning → Enumeration → Vulnerability Assessment → Exploitation → Remediation. All testing was authorised, contained within the private 192.168.56.0/24 subnet, and caused no impact to any external systems.

Total Vulnerabilities	Critical / High	Exploits Successful	Assessment Date
68	**6 Critical | 1 High**	**5 of 5 Attempted**	**18 March 2026**

All five exploitation attempts were successful, resulting in remote shell or Meterpreter sessions on the target machine. Root-level access was achieved via the Samba usermap_script exploit, confirming a critical security posture for the target system.

2. Methodology

The assessment followed the CEH v12 penetration testing lifecycle:

#	Phase	Activities Performed
1	**Footprinting & Recon**	Host discovery via Nmap ping scan on 192.168.56.0/24 — identified 4 live hosts
2	**Network Scanning**	Service and version detection (nmap -sV), OS fingerprinting on target 192.168.56.101
3	**Enumeration**	NetBIOS/SMB enumeration via nbtscan & enum4linux; web application fingerprinting
4	**Vulnerability Assessment**	Manual CVE analysis per service; automated scan using Nessus Essentials (68 findings)
5	**Exploitation**	5 exploits executed via Metasploit Framework: vsftpd, UnrealIRCd, Samba, DistCC, Java RMI
6	**Remediation**	Patch recommendations derived from Nessus remediation tab and CVE advisories

3. Footprinting & Reconnaissance

The first step was identifying the Kali Linux machine's own IP address and network interface configuration using the ip a command.

Kali Linux IP: 192.168.56.104/24 (eth1 — VirtualBox Host-Only Adapter)

3.1 Host Discovery

An Nmap ping scan was executed across the entire /24 subnet to identify live hosts. The command nmap -sn 192.168.56.0/24 returned four active hosts:

IP Address	MAC / Vendor	Role
192.168.56.1	0A:00:27:00:00:11 (Unknown)	VirtualBox Host-Only Gateway
192.168.56.100	08:00:27:AD:35 (Oracle VirtualBox)	VirtualBox DHCP Server
192.168.56.101 ★	08:00:27:1C:44:FF (Oracle VirtualBox)	TARGET — Metasploitable 2
192.168.56.104	08:00:27:37:9E:C2 (Oracle VirtualBox)	Kali Linux — Attacker Machine

The host at 192.168.56.101 was selected as the target because it exposed the largest number of open ports and services — a hallmark of the Metasploitable 2 vulnerable image.

4. Network Scanning

4.1 Service & Version Detection

A full service and version detection scan was run with nmap -sV 192.168.56.101. The scan completed in 16.39 seconds and revealed 23 open TCP ports across a wide range of services:

Port	Protocol	Service	Version / Banner
21	TCP	FTP	vsftpd 2.3.4 ⚠ BACKDOOR
22	TCP	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23	TCP	Telnet	Linux telnetd ⚠ PLAINTEXT
25	TCP	SMTP	Postfix smtpd
53	TCP	DNS	ISC BIND 9.4.2
80	TCP	HTTP	Apache httpd 2.2.8 (Ubuntu DAV/2)
139	TCP	SMB / NetBIOS	Samba smbd 3.X – 4.X (WORKGROUP) ⚠
445	TCP	SMB	Samba smbd 3.X – 4.X (WORKGROUP)
512	TCP	exec (rexecd)	netkit-rsh rexecd
513	TCP	login (rlogind)	OpenBSD or Solaris rlogind

514	TCP	shell (rshd)	Netkit rshd
1099	TCP	Java RMI	GNU Classpath grmiregistry ⚠
1524	TCP	Bind Shell	Metasploitable root shell ⚠ CRITICAL
2049	TCP	NFS	2-4 (RPC #100003)
2121	TCP	FTP (alt)	ProFTPD 1.3.1
3306	TCP	MySQL	MySQL 5.0.51a-3ubuntu5
5432	TCP	PostgreSQL	PostgreSQL DB 8.3.0 – 8.3.7
5900	TCP	VNC	VNC (protocol 3.3) ⚠ WEAK AUTH
6000	TCP	X11	(access denied)
6667	TCP	IRC	UnrealIRCd ⚠ BACKDOOR
8009	TCP	AJP13	Apache Jserv (Protocol v1.3)
8180	TCP	HTTP (alt)	Apache Tomcat/Coyote JSP engine 1.1

OS Detection: metasploitable.localdomain, irc.Metasploitable.LAN — Unix/Linux — linux_kernel CPE.

5. Enumeration

5.1 NetBIOS / SMB Enumeration (nbtscan + enum4linux)

Field	Value
NetBIOS Name	METASPLOITABLE
Domain / Workgroup	WORKGROUP
OS / Platform	metasploitable server (Samba 3.0.20-Debian), OS version 4.9
Server Type	0x9a03
Active Services	Workstation Service, Messenger Service, File Server Service, Master Browser
Null Session Auth	⚠ ENABLED — server accepts empty username/password connections
Known Usernames	administrator, guest, krbtgt, domain admins, root, bin, none
RID Range	500–550, 1000–1050

5.2 Web Application Enumeration

The HTTP service on port 80 (Apache 2.2.8) was accessed via browser at http://192.168.56.101. The default Metasploitable 2 web interface was discovered, hosting multiple intentionally vulnerable web applications:

Application	Description	Potential Attack Vectors
DVWA	Damn Vulnerable Web Application — multi-level practice target	SQLi, XSS, CSRF, File Upload, Command Injection
Mutillidae	OWASP Top 10 vulnerable web app	SQLi, XSS, Auth bypass, IDOR
phpMyAdmin	MySQL database management interface (web-based)	Credential brute-force, SQL exposure
TWiki	Web-based collaboration platform	Remote code execution (TWiki plugin exploit)
WebDAV	Web-based Distributed Authoring and Versioning	File upload, directory traversal

5.3 Database Service Enumeration

MySQL (port 3306) and PostgreSQL (port 5432) were both found open and accepting connections. Both services expose database access that, if using default or weak credentials, allows direct SQL queries and potential data exfiltration.

5.4 Weak Password Policy

The enum4linux tool retrieved the password policy from the SMB service. Key findings:

- Minimum password length: 5 characters (dangerously short)
- Password complexity: DISABLED
- Password history: Not configured — unlimited password reuse permitted
- Account lockout threshold: None — unlimited brute-force attempts allowed
- Password age: No maximum set

This policy effectively guarantees that brute-force and credential stuffing attacks face no resistance from the authentication system itself.

6. Vulnerability Assessment

6.1 Nessus Essentials Scan Summary

A full vulnerability scan was conducted using Nessus Essentials (Local Scanner, Policy: Basic Network Scan, CVSS v3.0). The scan ran from March 11, 2026 at 11:17 PM and completed in 14 minutes.

Critical	High	Medium	Low / Info
6	1	28+	33+

6.2 Critical & High Findings — Manual Analysis

#	Port	Service / Version	Severity	CVE / Vulnerability
1	21/TCP	vsftpd 2.3.4	CRITICAL	CVE-2011-2523 — Backdoor RCE → root shell
2	6667/TCP	UnrealIRCd	CRITICAL	CVE-2010-2075 — Backdoor RCE via crafted request
3	139,445/TCP	Samba 3.X	CRITICAL	CVE-2007-2447 — usermap_script → root shell
4	1524/TCP	Bind Shell	CRITICAL	Metasploitable root shell exposed — direct root access
5	8009/TCP	Apache Tomcat AJP	CRITICAL	CVE-2020-1938 (Ghostcat) — AJP connector file read/RCE
6	5900/TCP	VNC 3.3	CRITICAL	No/Weak VNC authentication — direct desktop access
7	1099/TCP	Java RMI Registry	HIGH	Insecure RMI endpoint — remote class loading → RCE
8	23/TCP	Telnet	HIGH	Plaintext credential transmission — credential interception
9	139,445/TCP	SMB Null Session	HIGH	Anonymous enumeration of users, shares, policies
10	Multiple	SSL v2/v3	MEDIUM	Deprecated SSL protocols — POODLE, DROWN attack surface
11	Multiple	Password Policy	HIGH	No complexity, no lockout — trivial brute-force

7. Exploitation

All exploitation was performed using msfconsole (Metasploit Framework v6.4.116-dev, 2,623 exploits) from Kali Linux against the isolated target at 192.168.56.101.

7.1 Exploit 1 — vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Field	Detail
Module	exploit/unix/ftp/vsftpd_234_backdoor
Target Port	21/TCP (FTP)
CVE	CVE-2011-2523
RHOSTS	192.168.56.101
LHOST	192.168.56.104
Payload	cmd/linux/http/x86/meterpreter_reverse_tcp
Result	✓ Meterpreter session 1 opened (192.168.56.104:4444 → 192.168.56.101:54626)
Access Level	Root shell — confirmed via whoami and sysinfo

How it works: vsftpd 2.3.4 contains a backdoor introduced via a supply-chain compromise. When a username ending with a smiley face ":)" is submitted on port 21, the daemon opens a bind shell on port 6200. Metasploit automates this trigger and connects a Meterpreter payload, granting full remote root shell access.

Post-Exploitation Capabilities Demonstrated:

- whoami — confirmed root-level identity
- sysinfo — retrieved hostname (metasploitable.localdomain), OS, and architecture
- ls / — browsed the full root filesystem including /etc, /home, /var, /root
- Meterpreter shell channel opened for interactive command execution

7.2 Exploit 2 — UnrealIRCd 3.2.8.1 Backdoor (CVE-2010-2075)

Field	Detail
Module	exploit/unix/irc/unreal_ircd_3281_backdoor
Target Port	6667/TCP (IRC)
CVE	CVE-2010-2075
Payload	cmd/linux/http/x86/meterpreter_reverse_tcp
Result	✓ Meterpreter session 2 opened (192.168.56.104:4444 → 192.168.56.101:51632)

Access Level	Remote shell on compromised IRC server — /etc/unreal directory browsed

How it works: A backdoor was secretly inserted into UnrealIRCd 3.2.8.1's source archive. Sending a crafted sequence prefixed with "AB;" to port 6667 triggers execution of arbitrary OS commands. Metasploit automates delivery and establishes a reverse Meterpreter session to the attacker.

Post-Exploitation Capabilities Demonstrated:

- ls /etc/unreal — confirmed access to IRC server configuration files
- Bidirectional command execution via Meterpreter session 2
- Potential for lateral movement and config file exfiltration

7.3 Exploit 3 — Samba Username Map Script (CVE-2007-2447)

Field	Detail
Module	exploit/multi/samba/usermap_script
Target Ports	139/TCP and 445/TCP (SMB)
CVE	CVE-2007-2447
Payload	cmd/unix/reverse_netcat
Result	✓ Command shell session 3 opened (192.168.56.104:4444 → 192.168.56.101:36130)
Access Level	ROOT — confirmed: uid=0(root) gid=0(root)

How it works: A vulnerability in Samba's username map script configuration allows an attacker to inject OS-level shell metacharacters into the username field of an SMB connection request. Samba executes the injected command as root. This is one of the most impactful vulnerabilities in Metasploitable 2, delivering immediate root access.

Post-Exploitation Capabilities Demonstrated:

- whoami → root | id → uid=0(root) gid=0(root)
- Full filesystem read/write access as root
- Ability to create persistent backdoors, modify /etc/passwd, exfiltrate /etc/shadow

7.4 Exploit 4 — DistCC Remote Command Execution (CVE-2004-2687)

Field	Detail
Module	exploit/unix/misc/distcc_exec
Target Port	3632/TCP (DistCC)

CVE	CVE-2004-2687
Payload	cmd/unix/reverse (switched from default after initial attempt)
Result	✓ Command shell session 4 opened (192.168.56.104:4444 → 192.168.56.101:38509)
Access Level	daemon user — whoami: daemon

How it works: The DistCC distributed compiler daemon (used to offload compilation to remote machines) accepts and executes arbitrary compiler commands without authentication. An attacker can embed shell commands in the compilation job, which DistCC executes on the server with daemon-level privileges.

Note: The initial exploit attempt using the default meterpreter payload failed due to missing file descriptors. The payload was switched to cmd/unix/reverse, which succeeded. This demonstrates the importance of payload selection during real-world engagements.

7.5 Exploit 5 — Java RMI Server Remote Code Execution

Field	Detail
Module	exploit/multi/misc/java_rmi_server
Target Port	1099/TCP (Java RMI Registry)
Technique	Insecure RMI registry → remote class loading → malicious JAR delivery
Payload	java/meterpreter/reverse_tcp (50,073 bytes sent)
Result	✓ Meterpreter session 5 opened (192.168.56.104:4444 → 192.168.56.101:37562)
Access Level	Remote Meterpreter session — filesystem access confirmed via ls /

How it works: The Java RMI registry running on port 1099 is configured to allow remote class loading from arbitrary URLs. The exploit stands up a temporary HTTP server on the attacker's machine, serves a malicious JAR file, and instructs the RMI registry to load and execute it. The result is a full Meterpreter session with the privileges of the Java process.

Post-Exploitation Capabilities Demonstrated:

- shell → Process 1 created, Channel 1 created
- ls / — full root filesystem listing: bin, boot, cdrom, dev, etc, home, initrd, initrd.img, lib...
- Meterpreter session for interactive post-exploitation

8. Exploitation Summary

#	Exploit	Module	Port	Access Level	Result
1	vsftpd Backdoor	vsftpd_234_backdoor	21	Root Shell	✓ SUCCESS
2	UnrealIRCd Backdoor	unreal_ircd_3281_backdoor	6667	Remote Shell	✓ SUCCESS
3	Samba Usermap Script	samba/usermap_script	139/445	ROOT (uid=0)	✓ SUCCESS
4	DistCC RCE	distcc_exec	3632	Daemon User	✓ SUCCESS
5	Java RMI RCE	java_rmi_server	1099	Meterpreter	✓ SUCCESS

All 5 out of 5 exploitation attempts succeeded. Root-level access (uid=0) was achieved in Exploits 1 and 3, demonstrating complete system compromise.

9. Remediation Recommendations

Based on Nessus scan findings and manual analysis, the following remediation steps are recommended in priority order:

Priority	Service	CVE(s)	Recommended Action
CRITICAL	vsftpd 2.3.4	CVE-2011-2523	Remove immediately. Replace with vsftpd ≥ 2.3.5 or use SFTP (OpenSSH). Consider disabling FTP entirely.
CRITICAL	UnrealIRCd	CVE-2010-2075	Remove compromised binary. Upgrade to UnrealIRCd ≥ 3.2.8.2 with verified checksum.
CRITICAL	Samba 3.X	CVE-2007-2447	Upgrade to Samba ≥ 4.2.11 / 4.3.8 / 4.4.2 or later (per Nessus remediation). Disable username map script.
CRITICAL	Bind Shell :1524	N/A	Close port 1524 immediately. Audit system for any backdoor binaries. Perform full reinstall if compromise confirmed.
CRITICAL	VNC (no auth)	N/A	Disable VNC or enforce strong VNC password. Prefer SSH tunnelling for remote access.
CRITICAL	Apache Tomcat AJP	CVE-2020-1938	Disable AJP connector in server.xml if unused, or restrict to localhost only. Upgrade Tomcat.
HIGH	Telnet :23	N/A	Disable Telnet. Use SSH exclusively for remote administration.
HIGH	Java RMI :1099	N/A	Disable public RMI registry. Restrict to localhost. Apply Java security policy to block remote class loading.
HIGH	SMB Null Sessions	N/A	Set restrict anonymous = 2 in smb.conf. Disable anonymous enumeration.

HIGH	Password Policy	N/A	Enforce minimum 12-character passwords, complexity requirements, lockout after 5 failed attempts.
MEDIUM	ISC BIND 9.4.2	Multiple	Upgrade to BIND ≥ 9.11.22 / 9.16.6 / 9.17.4 (per Nessus). Restrict zone transfers.
MEDIUM	SSL v2/v3	N/A	Disable SSLv2 and SSLv3. Enable TLS 1.2 and TLS 1.3 only.

10. Conclusion

This penetration test against Metasploitable 2 demonstrated a complete system compromise through multiple independent attack paths. The assessment covered all major phases of the ethical hacking lifecycle and successfully exploited five distinct vulnerabilities, achieving root-level access via two separate exploits.

Key takeaways from the engagement:

- Software supply-chain backdoors (vsftpd, UnrealIRCd) represent an extreme risk — even a single unverified binary can lead to full system compromise.
- Samba misconfiguration combined with the username map script vulnerability grants immediate root access with no further privilege escalation required.
- A total of 68 vulnerabilities — including 6 Critical — were identified by Nessus, underscoring the importance of regular, automated vulnerability scanning in any security programme.
- The complete absence of a meaningful password policy eliminates the last line of defence against credential-based attacks.
- Legacy protocols (Telnet, SSLv2/v3, FTP) should be treated as critical risks and removed from any system connected to a network.

Applying the remediation steps outlined in Section 9 — particularly upgrading vulnerable services, enforcing a strong authentication policy, and disabling unused legacy protocols — would eliminate all identified critical and high-severity vulnerabilities and substantially improve the security posture of the system.

⚠ *LEGAL DISCLAIMER — This assessment was conducted exclusively in an isolated VirtualBox lab environment against Metasploitable 2, a purposely vulnerable system. All activities were authorised and performed for educational purposes only as part of the CEH certification portfolio. No real systems, networks, or individuals were targeted. Performing these techniques against systems without explicit written authorisation is illegal under India's Information Technology Act, 2000 and equivalent cybercrime statutes worldwide.* ⚠